

Kifisias Avenue 1-3, 11523 Athens

T: 210 6475 600 • E: contact@dpa.gr • www.dpa.gr

Athens, 15-04-2024

Protocol No.: 1155

Decision 3/2024

(Single-Member Body)

The President of the Authority, as a single-member body pursuant to Article 17 paragraph 1 of Law 4624/2019 (Government Gazette A' 137), within the framework of the powers provided in Articles 4 paragraph 3 and 10 paragraph 4 of the Authority's Operating Regulation (Government Gazette B' 879/25.02.2022), convened via teleconference on January 25, 2024, in order to examine the case referred to below in the background of this decision. Present without voting rights were Charis Symeonidou, legal auditor – lawyer, and Irini Papageorgopoulou, employee of the administrative affairs department, as secretary.

The Authority took into account the following:

1.

With the complaint No. G/EIS/12590/15-12-2022, A (hereinafter referred to as the complainant) is directed against the company named "GROUP MEDICAL DIAGNOSIS – PRIVATE MULTISPECIALTY CLINIC – MEDICAL S.A." (hereinafter referred to as the respondent), alleging a violation of the confidentiality of her personal data. Specifically, according to the complaint, on ... an employee of the respondent's Diagnostic Center in [location] X disclosed the results of the complainant's examinations to her father over the phone, without her having given her consent for this and specifically without having stated her father's phone number and details as a person authorized to receive the results of her examinations on her behalf. The complainant argues that in this way her medical confidentiality and personal health data were violated and that her elderly father was distressed; she also states that she subsequently informed the respondent about the above incident through her communication with B, the director of the Diagnostic Center in [location] X, who admitted the incident and apologized.

2.

In the context of investigating the above complaint, the Authority, with document No. G/EXE/655/13-03-2023, communicated the relevant documents to the respondent and invited it to express its views on the allegations, specifically clarifying the following: a) what is the procedure followed by the respondent for providing examination results via telephone and what security measures it has taken to ensure the confidentiality and protection of medical confidentiality, in accordance with Articles 24 and 32 of the GDPR, submitting its relevant Policy; b) whether this Policy was adhered to in the case of the alleged factual incidents, specifically stating what procedure was followed by the respondent for informing the complainant regarding the results of her examinations; c) whether the respondent, after being informed by the complainant about the incident, handled it as a personal data breach incident and what actions it took in this regard. In its response No. G/EIS/2283/28-03-2023, the respondent company stated the following:

- that indeed the complainant had visited the facilities of its Diagnostic Center in X on ... to undergo examinations, and upon her arrival, she was informed by the reception about the respondent's Data Protection Policy and filled out the form E3 titled "CONSENT FORM FOR THE SENDING OF RESULTS" (submitted as reference 1), which was recorded in the respondent's file. From the form, it appears that the method of delivery of the results chosen by the complainant was via email, and as the respondent points out, in such cases, the method of encrypting the documents sent is followed.

- That during the collection of the complainant's details, the employee at the reception requested her contact phone number, in case the diagnostic laboratory needed to contact her, and that the complainant provided the mobile phone number ... and the landline number To prove this, the respondent submits and refers to a screenshot of the complainant's customer file, which shows the

aforementioned contact details (reference 2).

- That subsequently, the diagnostic center needed to contact the complainant, as the results of the examinations indicated that two antibiotic tests were necessary instead of one, as was provided for and covered by the initial referral from EOPYY, and therefore the complainant had to give her approval for the coverage of additional medical services. For this reason, they called the above mobile phone number that had been provided by the complainant.

- That after repeated attempts, a gentleman answered the phone who stated that he was the complainant's father, confirmed that it was indeed her mobile phone, that she was absent at that moment and had left her mobile phone with him. According to the respondent, the person who called on behalf of the diagnostic center did not disclose any health information of the complainant to her father but informed him that it was a personal matter and asked him to inform her that they wished to contact the diagnostic center.

- That later, on the same day, the complainant indeed contacted the Diagnostic Center by phone, accepted the additional service, and complained about the violation of her personal data, stating that she intended to file a complaint.

4

- That the complainant's test results were sent via e-mail on ... in a encrypted file, for which the use of a password was necessary, which the complainant received during her visit, as evidenced by a relevant screenshot of the message (refer to 3).

- Furthermore, the respondent mentioned the security measures it takes to ensure the confidentiality of data and emphasized that under no circumstances are test results disclosed orally over the phone to a person who is not identified with the unique patient code according to the Company's Confidentiality Policy – Personal Data Protection and the training received by its secretarial staff, while it also referred to the Security Policy of the Medical Diagnosis Group and the Acceptable Use Policy of Information and Communication Systems of the Group.

- Finally, the respondent argued that the complainant misunderstood the courtesy of the Center's Director, as there was no admission of the incident and no apology from her. On the contrary, the Director informed the complainant that during the relevant phone call, the secretary revealed to the complainant's father only the name of the company and that it is a diagnostic center, without this constituting a disclosure of the patient's personal data. That in any case, and for the purpose of continuously improving the level of protection of patients' personal data, she made recommendations to her secretarial staff not to disclose any information over the phone before identifying the subject, especially when the call is answered by a person of the opposite gender to that of the patient. Ultimately, the position of the respondent company was that the mobile phone number ... was provided by the complainant during her visit to the diagnostic center, that no health information about her was given to her father during the call, and that therefore there was no incident of data breach.

Following the above document, the Authority, with document G/EXE/952/20-04-2023, requested the complainant to confirm the respondent's assertion that during her mentioned visit on ... to the alleged diagnostic center, she provided the mobile phone number ... as a contact detail, to which the relevant call was made. With the supplementary document G/EIS/3121/28-04-2023, the complainant denies that she provided the above number and refers to Form No. 3 that she completed during her visit, stating that she always provides her own mobile phone number (... – submitting supporting documentation, see refer to 1-3) and that the client file does not constitute proof that this number was declared by her, given that the details of the client file in various management programs can be modified. Additionally, the complainant disputes that her father stated that the said number belongs to her and

that he was absent at the given time, as she mentions that for the last two years they have not lived in the same house, while emphasizing the fact that during the said call, the test results were given to her father, the name of the test that needed to be done (additional antibiogram), and the information that she needed to call urgently to approve the additional cost. Finally, she reiterates the claim that the Diagnostic Center admitted its mistake with the phrase "what's done is done, now it can't be undone" and that as a result of her complaint, she was ultimately not charged for the cost of the additional test, while the Diagnostic Center apologized to her.

Subsequently, with document G/EXE/2319/14-09-2023, the Authority communicated the above views of the complainant to the respondent and requested it to respond to them by providing any relevant supporting evidence. The respondent, with its response document G/EIS/7222/13-10-2023, argues that the updating of contact details in client files is done within the framework of adhering to the principle of accuracy during their personal presence at the diagnostic centers and according to their declaration, and that the relevant process is not identical to the process of declaring the method of receiving test results, through Form E3 which is completed and signed each time by the patients. Furthermore, the respondent states that the father of the complainant is not a client, has never attended its diagnostic centers, and does not have a file.

6

client, therefore could not have been called by mistake due to a name similarity, reiterating that the source of the number called in this case was the complainant herself, who provided this number orally during her visit. The respondent maintains that during the call, no information regarding the health of the complainant was disclosed to her father and that there was no apology from her side. Finally, it argues that the complaint is unproven, unfounded, and constitutes an attempt at financial gain on the part of the complainant, who on ... served an extrajudicial statement to the company proposing an out-of-court settlement regarding the incident in exchange for compensation.

3.

Following the above, the Authority, with its calls G/EXE/151/11-01-2024 and G/EXE/150/11-01-2024, summoned the complainant and the respondent to a hearing before the President of the Authority as a sole member on 25/1/2024, in order to present their views on the case. Present at the hearing before the President was the complainant, and on behalf of the respondent company were B, Director of Health Unit X, G, General Director of the Medical Diagnosis Group Network – CENTRAL LAB, and the lawyers from Athens Evangelos Katsikis (A.M. D.S. ...) and Orfeas Mavreadakis (A.M. D.S. ...). Also present was the D.P.D., D. During the hearing, the parties presented their claims, were given a deadline, and submitted timely, the complainant submitting the document with reference number G/EIS/802/1-2-2024, and the respondent submitting the document with reference number G/EIS/834/2-2-2024.

The complainant, both during the hearing and with her memorandum, reiterated the claims she made in her complaint and in her supplementary document G/EIS/3121/28-04-2023, emphasizing particularly that she never provided her father's mobile phone number to the respondent diagnostic center and that despite the fact that it was a ... examination, the secretary who called this number and heard a male voice provided the caller, her father, with information regarding the examination, without any identification process and without her, as the data subject, having given her consent for such. She pointed out that her father has also visited the diagnostic center as a client and that, in her opinion, this was the reason he was mistakenly called by the secretary, due to his patronymic appearing on the patient file and the common surname. Finally, she emphasized that her elderly father, after receiving the information that "his daughter has ..." suffered distress and harm to his health (...), while she herself suffered moral damage from the incident.

The respondent, orally through its representatives during the hearing, stated that it does not keep the contact details of the patients who visit it and that at each visit this information is updated orally, as

declared by the patients at the reception. It argued that in the telephone communication it had with the complainant's father, no information regarding her health was provided, given that, in any case, the secretaries do not have access to the examination results, but only to the contact details. As it stated, in this case, medical reasons necessitated immediate communication with the examined individual, in order to obtain approval for the further examination needed; for this reason, the method of communication chosen was a call to the mobile phone rather than the landline, so that the called party, if unable to answer, could be informed of the call and call the diagnostic center back. According to the respondent company, the complaint in question has been submitted as a means of enrichment by the complainant, who has sought "an out-of-court settlement" through the sending of an extrajudicial statement, vaguely claiming moral damage to her father from the aforementioned telephone communication, while, as the respondent argues, no similar incident has ever been recorded. In response to a question regarding the organizational security measures it implements, the respondent emphasized that through its information system, where access levels for staff (role-based access) are maintained, the reception staff do not have access to the examination results of the patients, and it noted that as part of the ongoing updating of these measures, in the future, the declaration of the contact details of the patients will be done through electronic registration directly by them using a tablet with a stylus.

8

at the time of the visit and following full identification using an identity document. In its memorandum G/EIS/834/02-02-2024, the respondent pointed out that the aforementioned update of its procedures is a decision of the administration and is expected to be implemented within 1-2 months, emphasizing that it does not constitute an admission of error nor is it related to any violation of the rights of the subjects. Furthermore, in its memorandum, the respondent submitted the out-of-court statement from the complainant dated ..., in which the latter claimed monetary compensation for her moral damage, as well as the out-of-court response from the respondent company dated Additionally, it submitted the document with code D.520 titled "Information System Management," which describes the classified access of personnel to its Information System. The Authority, after examining all the elements of the file and those arising during the hearing process,

CONSIDERED IN ACCORDANCE WITH THE LAW

1. According to Article 2, paragraph 1 of the General Data Protection Regulation (Regulation (EU) 2016/679 – hereinafter, GDPR) "This regulation applies to the, in whole or in part, automated processing of personal data, as well as to the non-automated processing of such data which are included or are intended to be included in a filing system." As processing is understood, according to Article 4, point 2 of the GDPR, "any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction." Therefore, the collection, recording, and storage of information, such as the phone number and the results of medical examinations of the data subject, in the information system of the data controller, constitute data processing falling within the material scope of the GDPR. Furthermore, from the provisions of Articles 51 and 55 of the GDPR and Article 9 of Law 4624/2019 (Government Gazette A' 137), it follows that the Authority has the competence to supervise the application of the provisions of the GDPR, this law, and other regulations concerning the protection of individuals from the processing of personal data. According to the above, the Authority has the competence, under the provisions of Articles 57, paragraph 1, point (f) of the GDPR and 13, paragraph 1, point (z) of Law 4624/2019, to address the complaint of A against "MEDICAL DIAGNOSIS GROUP – PRIVATE POLYCLINIC – MEDICAL S.A." and to exercise, correspondingly, its powers provided for in the provisions of Articles 58 of the GDPR and 15 of Law 4624/2019.

2. With Article 5, paragraph 1 of the General Regulation (EU) 2016/679 for the protection of natural persons against the processing of personal data (hereinafter GDPR), the principles that must govern processing are established. According to Article 5, paragraph 1 (a), (d), and (f) of the GDPR "1.

Personal data: (a) shall be processed lawfully and fairly in a transparent manner in relation to the data subject ('lawfulness, fairness, and transparency'), [...], (d) are accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, with respect to the purposes of the processing, are erased or rectified without delay ('accuracy'), [...] (f) shall be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')." Moreover, according to Recital 39 of the GDPR "Personal data should be processed in a manner that ensures appropriate security and confidentiality of personal data, including protection against unauthorized processing."

10

"access to this personal data (...)" Furthermore, according to the principle of accountability explicitly introduced by the paragraph of the above Article 5, which constitutes a cornerstone of the GDPR, the data controller "bears the responsibility and is able to demonstrate compliance with paragraph 1 ('accountability')". This principle entails the obligation of the data controller to be able to demonstrate compliance with the principles of Article 5 paragraph 1.

3. Every processing operation must be lawful and must be based on at least one of the legal bases of Article 6 GDPR. Furthermore, according to Article 9 paragraph 1 GDPR "1. The processing of [...] data concerning health [...] is prohibited", while paragraph 2 of the same article enumerates exhaustively the exceptions to the above prohibition on processing special categories of data as per paragraph 1. In the provision of Article 4 point 15 of the GDPR, data concerning health is defined as: "personal data related to the physical or mental health of a natural person, including the provision of health care services, and which reveal information about the health status of the individual."

4. According to Article 24 paragraphs 1 and 2 GDPR "1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is performed in accordance with this Regulation. Such measures shall be reviewed and updated when necessary. 2. Where justified in relation to the processing activities, the measures referred to in paragraph 1 shall include the implementation of appropriate policies for the protection of data by the data controller", while according to the provisions of paragraphs 1 and 2 of Article 32 GDPR regarding the security of processing, "1. Taking into account the latest developments, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure an appropriate level of security against the risks, [...] 2. In assessing the appropriate level of security, particular consideration shall be given to the risks arising from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed."

5. According to Article 4 point 12 GDPR, a personal data breach is defined as "a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure, or access to personal data that has been transmitted, stored, or otherwise processed." According to the Guidelines 18/2018 of the Article 29 Working Party of Directive 95/46/EC (now European Data Protection Board) on Personal Data Breach Notification ("Guidelines on Personal data breach notification under Regulation 2016/679" WP 250 rev. 1), one type of personal data breach is categorized based on the security principle of "confidentiality", when unauthorized access to personal data is identified ("confidentiality breach").

6. Because in this case, from the examination of all the elements of the file and the evaluation of the claims of the complainant and the reported diagnostic center that were developed during the hearing and with the corresponding submissions, there was no certainty regarding the content of the telephone conversation between the employees of the secretariat of the reported diagnostic center and the father of the complainant on ..., it is therefore not established that the reported leak of personal data of the

complainant, namely the results of the medical examinations, has occurred, given that,

12

According to the classified access of the employees of the reported company to its Information System, the secretarial staff does not have access to the health data of the subjects. Furthermore, it appears that, at the time of the reported incidents, the collection of patients' contact details by the reported company was done in accordance with their verbal statement during the visit, while, upon consideration of the case data, it is not proven that the number ending in -..., which was called by the Diagnostic Center, was obtained, as a contact detail with the complainant, in a manner different from that of its employees. Moreover, as determined in the context of a spontaneous examination of the technical and organizational security measures and related policies maintained by the reported company as the data controller, following a review and within the framework of the ongoing updating of its procedures, henceforth the registration of customers' contact details will be done with a signed entry on a tablet by themselves using a stylus. Therefore, the alleged violation of the principle of confidentiality of the complainant's data is not established, while it appears that the reported company acts in compliance with the provisions of Articles 32 and 24 paragraphs 1 and 2 of the GDPR. Following the above, it is determined that there is no case for exercising the corrective powers of the Authority under Article 58 paragraph 2 of the GDPR.

FOR THESE REASONS

THE AUTHORITY

Rejects the complaint of A. under consideration.

THE PRESIDENT

Konstantinos Menoudakos

THE SECRETARY

Irini Papageorgopoulou